

# Diseño Estratégico de Auditorías de Ciberseguridad



Calibrando el Enfoque y el Alcance del Pentesting

Consultoría de Riesgos Tecnológicos  
División de Hacking Ético

Presentado por Carlos Noboa



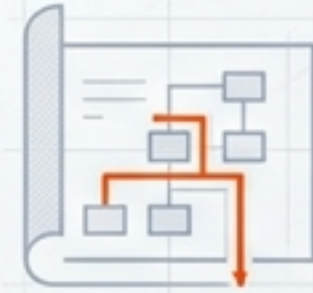
# La Anatomía de un Pentest Efectivo

Cada auditoría de hacking ético requiere una calibración precisa para maximizar sus objetivos. Esta planificación se define por dos dimensiones estratégicas fundamentales:



## Asimetría de Información (El Enfoque)

¿Cuánto conocimiento y visibilidad previa le otorgamos al atacante simulado?



## Vector de Penetración (El Alcance)

¿Cuáles son los límites geográficos y de profundidad de la simulación?



# Dimensión 1: El Enfoque de la Auditoría

El enfoque determina la perspectiva del auditor frente a la infraestructura. Se clasifica según el nivel de conocimiento previo de los sistemas, usuarios y código fuente proporcionado al pentester.



Visibilidad Cero  
(Caja Negra)

Visibilidad Parcial  
(Caja Gris)

Visibilidad Total  
(Caja Blanca)



# Matriz Comparativa de Enfoques



## Caja Negra

- Conocimiento: Ninguno previo sobre la infraestructura o sistemas.
- Simulación: Emula las acciones de un atacante real externo.



## Caja Gris

- Conocimiento: Combinado. Dispone de usuarios sin privilegios y cierto detalle de las funcionalidades.
- Simulación: Emula a un usuario interno o atacante con acceso inicial.



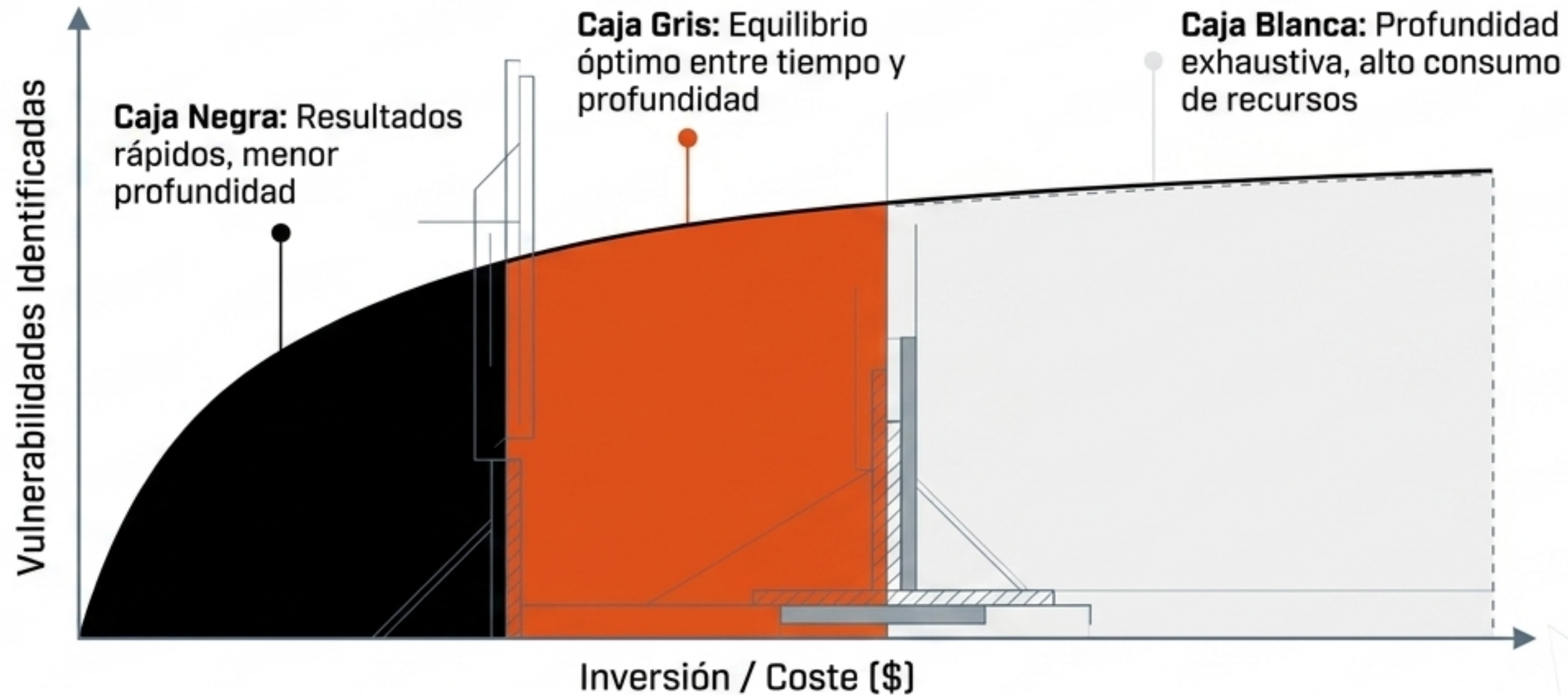
## Caja Blanca

- Conocimiento: Completo. Acceso a infraestructura, sistemas, usuarios y código fuente.
- Simulación: Auditoría profunda (visión de desarrollador o administrador).

Consideración Estratégica: Cada enfoque presenta beneficios e inconvenientes relacionados con el tiempo de auditoría y su profundidad.



# La Curva de Rendimiento: Optimizando los Resultados

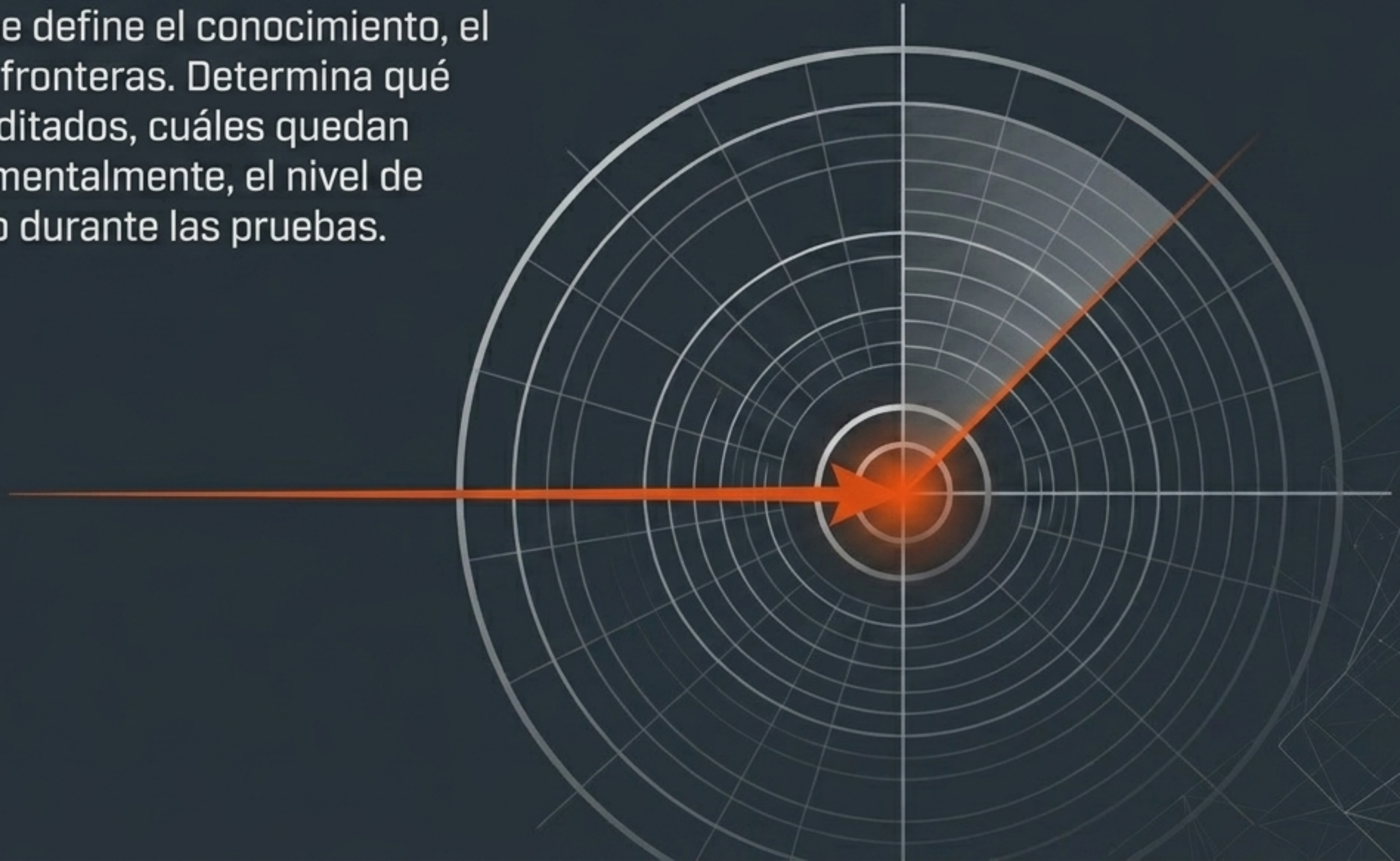


Conviene utilizar un enfoque que maximice los objetivos del pentest de acuerdo al presupuesto y tiempo disponible.



## Dimensión 2: El Alcance de la Auditoría

Mientras el enfoque define el conocimiento, el alcance define las fronteras. Determina qué sistemas serán auditados, cuáles quedan excluidos y, fundamentalmente, el nivel de intrusión permitido durante las pruebas.





# Amplitud vs. Profundidad

## Alcance Horizontal (Amplitud)

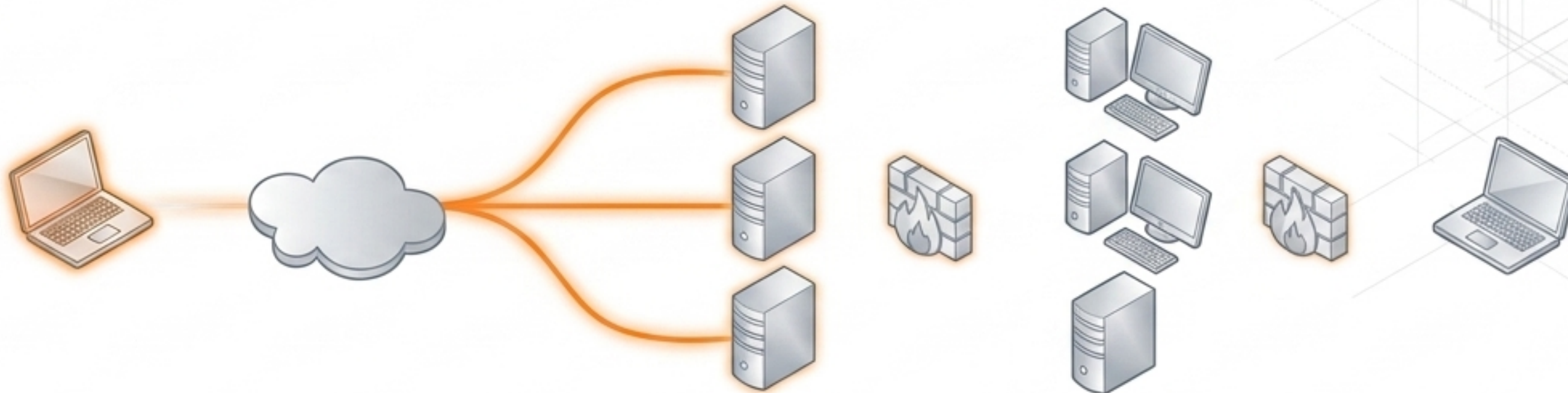
- Objetivo Principal: Revisar todos los activos visibles desde internet o desde una determinada red.
- Explotación: Normalmente no se contempla la explotación activa de las vulnerabilidades detectadas.
- Nivel de Intrusión: **Poco intrusivo.**

## Alcance Vertical (Profundidad)

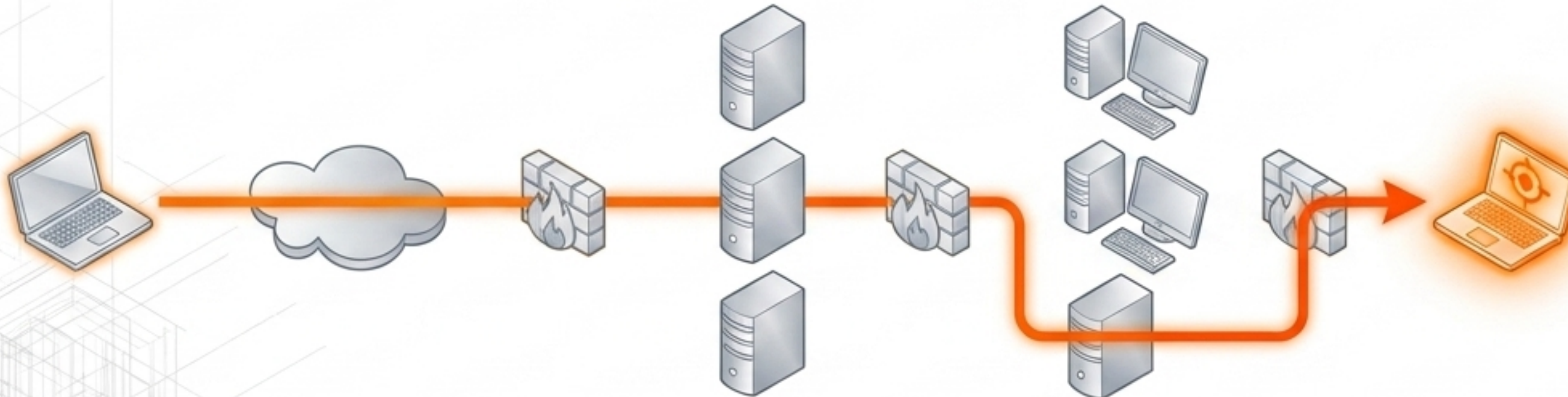
- Objetivo Principal: Comprometer el activo de mayor valor con el máximo privilegio posible (ej. bases de datos de negocio).
- Explotación: Se explotan todas las vulnerabilidades que permitan acceso al sistema.
- Nivel de Intrusión: **Intrusivo.**



# Topografía de los Vectores de Ataque



**Mapeo de superficie (Horizontal)**

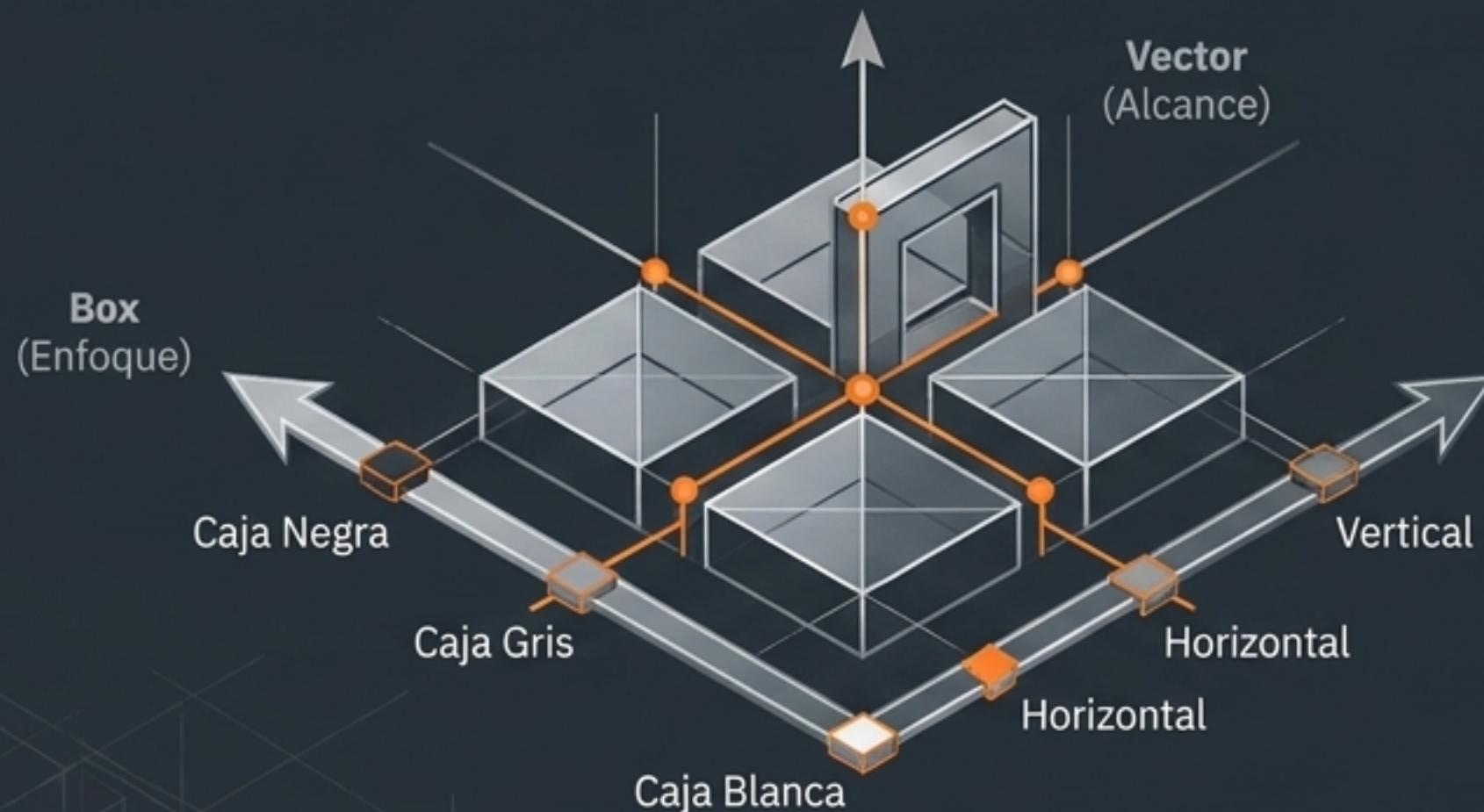


**Compromiso de activos críticos (Vertical)**



# El Blueprint Final: Diseñando el Pentest

La auditoría perfecta no existe de forma predeterminada; se construye.



- El **Enfoque** (Caja Negra, Gris, Blanca) determina la visión y el punto de partida del atacante.
- El **Alcance** (Horizontal, Vertical) define las reglas de enfrentamiento y el impacto permitido.

**La combinación de estas dos dimensiones permite a las organizaciones diseñar una auditoría que responda exactamente a sus sospechas de riesgo, maximizando el valor de los resultados y asegurando la protección de la información corporativa.**